Encryption and Key Management Policy

Document control	
Company	LogistiComp S.A.
Document ID	LC-POL-008
Version	1.4
Classification	Internal – may be shared with customers under NDA
Owner	Chief Information Security Officer (CISO)
Approved by	Information Security Steering Committee (ISSC)
Effective date	15 January 2026
Next review	January 2027

1. Purpose

This policy defines how LogistiComp S.A. uses encryption to protect information when it is stored and when it is transmitted, and how encryption keys, certificates and other secrets are created, stored, rotated and destroyed.

2. Scope

This policy applies to all LogistiComp systems that store or transmit Confidential or Restricted information (LC-POL-001, Section 7), including LogistiComp WMS, its backups, Company laptops and the corporate systems.

3. Roles and Responsibilities

- **CISO:** owns this policy and approves the list of permitted algorithms.
- **Platform engineering team:** configures encryption in the production environment and manages keys and certificates.
- **Engineering leads:** make sure that applications use only approved algorithms and libraries.

4. Approved and Prohibited Algorithms

Only well-established, publicly reviewed algorithms and standard cryptographic libraries may be used. Engineers must not develop their own cryptographic algorithms.

Purpose	Approved	Prohibited
Symmetric encryption	AES with 256-bit keys (AES-256), in GCM mode where possible	DES, 3DES, RC4

Purpose	Approved	Prohibited
Asymmetric encryption and signatures	RSA with keys of at least 3072 bits; ECDSA with curve P-256 or stronger	RSA keys shorter than 2048 bits
Hashing	SHA-256 or stronger	MD5, SHA-1
Password storage	Argon2id or bcrypt, with a unique salt per password	Unsalted or reversible storage
Transport protocols	TLS 1.2 and TLS 1.3	SSL, TLS 1.0, TLS 1.1

5. Encryption of Data at Rest

All Restricted and Confidential data is encrypted at rest with **AES-256**:

- **LogistiComp WMS databases:** encrypted with transparent data encryption.
- **File and object storage:** encrypted by Azure storage service encryption.
- **Backups:** encrypted, as required by the Backup and Data Retention Policy (LC-POL-005).
- **Company laptops:** full-disk encryption with BitLocker (XTS-AES 256).

Removable media may only hold Company information if they are encrypted and approved under the Removable Media Policy (LC-POL-010).

6. Encryption of Data in Transit

- All connections to LogistiComp WMS, including the web application, the APIs and the integrations with customers' systems, require **TLS 1.2 or higher**. TLS 1.3 is preferred where the client supports it. SSL, TLS 1.0 and TLS 1.1 are disabled.
- The web application sends HTTP Strict Transport Security (HSTS) headers, so browsers only connect over HTTPS.
- Electronic data interchange (EDI) files are exchanged only over encrypted channels: SFTP or AS2 with encryption. Unencrypted FTP is not supported.
- Traffic between services inside the production environment is also encrypted with TLS.
- Administrative access to the production environment is only possible through the bastion host over encrypted connections (LC-POL-002, Section 6).

7. Key Management

- **Storage:** encryption keys are stored in **Azure Key Vault**, using hardware security module (HSM)-backed keys for the keys that protect production data. Keys are never stored in source code, configuration files or on laptops.
- **Access:** access to Key Vault is limited to the platform engineering team and to the applications that need the keys, through managed identities. People who administer the databases do not have permission to manage the keys that encrypt them.
- **Logging:** every operation on keys is logged and sent to the SIEM (LC-POL-001, Section 11.3).

- **Rotation:** encryption keys are rotated **at least annually**, and immediately if a key is suspected to be compromised.
- **Backup of keys:** Key Vault is protected with soft-delete and purge protection, so keys cannot be permanently deleted by mistake.
- **Destruction:** when data must be destroyed, deleting the keys that encrypt it makes any remaining copies unreadable (crypto-shredding, see LC-POL-005, Section 9).

8. Certificates

TLS certificates for public LogistiComp services are issued by a publicly trusted certificate authority and are renewed automatically. Certificate expiry dates are monitored, and an alert is sent to the platform engineering team 30 days before a certificate expires. Private keys of certificates are stored in Azure Key Vault.

9. Secrets

Passwords, API keys, connection strings and other secrets used by applications are stored in Azure Key Vault and are read by the applications at runtime. Secrets are rotated at least annually, and immediately if they may have been exposed, for example when a person with access to them leaves the Company. Credentials of service accounts must meet the requirements in LC-POL-002, Section 8.2.

10. Exceptions

Any use of an algorithm, key length or protocol not approved in Section 4 requires an exception approved by the CISO under LC-POL-001, Section 18.

11. Review

This policy is reviewed at least annually by the CISO and approved by the ISSC, and also when weaknesses are published in any of the approved algorithms.